USDT0 · SECURITY REVIEW

USDT0
Celo XAUT0 Upgrade and USAT Deployment.

A security review of Celo XAUT0 Upgrade and USAT Deployment.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
USDT0	Celo XAUT0 Upgrade and USAT Deployment	Guardian	March 25 – March 31, 2026	March 31, 2026

§ 00

Contents.

12 pages: overview, confidence ranking, scope, 3 findings, disclaimer, and about Guardian.

§ 01 **Overview** P. 03

§ 02 **Confidence Ranking** P. 04

§ 03 **Scope & Classifications** P. 05

§ 04 **Findings** P. 06

Main Review · 3 findings P. 07

§ 05 **Disclaimer** P. 11

§ 06 **About Guardian** P. 12

§ 01

Overview.

Guardian reviewed Celo XAUT0 Upgrade and USAT Deployment across a single review round. The final report includes 2 Low, 1 Informational findings.

AUDIT FIRM
Guardian

CLIENT
USDT0

PROJECT
Celo XAUT0 Upgrade and USAT Deployment

PREPARED BY
Guardian

AUDIT WINDOW
March 25 – March 31, 2026

FINAL REPORT
March 31, 2026

REPOSITORY
https://github.com/Everdawn-Labs/usdt0-tether-contracts-hardhat

METHODOLOGY
Smart contract · Manual · Main Review

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer's assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	**0**	0	0	0	0
High	**0**	0	0	0	0
Medium	**0**	0	0	0	0
Low	**2**	2	0	0	0
Informational	**1**	1	0	0	0
All severities	**3**	**3**	**0**	**0**	**0**

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed Celo XAUT0 Upgrade and USAT Deployment in `https://github.com/Everdawn-Labs/usdt0-tether-contracts-hardhat`.

IN SCOPE

https://gist.github.com/GuardianAudits/bb273dd2d8dd739969c96aebc61fd0c0

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH	Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.
IMPACT · MEDIUM	Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.
IMPACT · LOW	Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.
LIKELIHOOD · HIGH	Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.
LIKELIHOOD · MEDIUM	Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.
LIKELIHOOD · LOW	Unlikely to ever occur in production.

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in. Status is where each finding ended up; its own page says how.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
L-01	**Misleading Modifier Name**	Best Practices	LOW	PENDING	p. 7
L-02	**Incomplete Error Message**	Best Practices	LOW	PENDING	p. 8
I-01	Potentially Outdated creditGasFees Interface	Informational	INFORMATIONAL	PENDING	p. 9

LOW **L-01** PENDING

Misleading Modifier Name

CATEGORY	Best Practices
LOCATION	CeloExtension.sol:27-30
REVIEW	Main Review

DESCRIPTION

The `onlyFeeWrapper` modifier in CeloExtension.sol:27 permits calls from both `address(0)` (the VM) and the `feeCurrencyWrapper`. The name `onlyFeeWrapper` suggests only the fee wrapper is authorized, omitting the fact that the VM (`address(0)`) is also an allowed caller.
Location: CeloExtension.sol:27-30

```
modifier onlyFeeWrapper() {
require(msg.sender == address(0) || msg.sender == feeCurrencyWrapper, "Only VM can call");
_;
}
```

RECOMMENDATION

Rename the modifier to `onlyFeeWrapperOrVM` (or `onlyVMOrFeeWrapper`) to accurately describe both permitted callers.

RESOLUTION

Status: Pending.

LOW **L-02**

PENDING

Incomplete Error Message

CATEGORY	Best Practices
LOCATION	CeloExtension.sol:28
REVIEW	Main Review

DESCRIPTION

The require statement's revert string is `"Only VM can call"`, but the condition also allows `feeCurrencyWrapper`. If a call reverts, the error message misleads the caller into thinking only the VM is authorized, when in reality the fee currency wrapper is also a valid caller.
Location: CeloExtension.sol:28
`require(msg.sender == address(0) || msg.sender == feeCurrencyWrapper, "Only VM can call");`

RECOMMENDATION

Update the error message to reflect both allowed callers, e.g.:
`"Only VM or FeeCurrencyWrapper can call"`

RESOLUTION

Status: Pending.

INFORMATIONAL **I-01** PENDING

Potentially Outdated creditGasFees Interface

CATEGORY	Informational
LOCATION	CeloExtension.sol:52-72
REVIEW	Main Review

DESCRIPTION

The `creditGasFees` function in CeloExtension.sol:52-72 uses the old 8-parameter signature (with the unused `gatewayFeeRecipient` and `gatewayFeeAmount` parameters). Celo's [fee-currency-example](https://github.com/celo-org/fee-currency-example/blob/92e2fcb32187ab7e27eab83d62fb4983a1d644a2/src/IFeeCurrency.sol#L41) repository indicates they are moving to a simplified signature that removes these legacy gateway fee parameters. This comment is \~2 years old, and the timeline for enforcement is unclear.

If Celo proceeds with this change at the protocol level, contracts using the old signature may break or become incompatible with the fee currency system.

Location: CeloExtension.sol:52-72

```
function creditGasFees(
address refundRecipient,
address tipRecipient,
address , // gateWayFeeRecipient is not used anymore
address baseFeeRecipient,
uint256 refundAmount,
uint256 tipAmount,
uint256 ,
uint256 baseFeeAmount
) external onlyFeeWrapper {
```

RECOMMENDATION

Confirm with the Celo team whether and when they plan to enforce the new `creditGasFees` signature at the protocol level. If the migration is imminent, consider adopting the new interface for USDT/USAT now (since these are fresh deployments), while keeping backward compatibility for already-deployed contracts like XAUT0. If the timeline is distant or uncertain, the current approach is acceptable but should be revisited before Celo's migration goes live.

I-01 Potentially Outdated creditGasFees Interface CONTINUED

RESOLUTION

Status: Pending.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

$45B+
DIGITAL ASSETS UNDER REVIEW

200+
ENGAGEMENTS COMPLETED

500+
CRITICAL & HIGH FINDINGS REPORTED

Reach us at audits@guardianaudits.com.